Dossier de Gouvernance - NovaTech

Auteurs / Équipe Projet : Brandon | Amine | Rayan
Date : Novembre 2026

---

1. Cadres de Référence et Conformité

Pour encadrer l'exploitation et la sécurité du Système d'Information de NovaTech, la gouvernance s'appuie sur des standards internationaux et des référentiels institutionnels reconnus :

- **ITIL 4 (Information Technology Infrastructure Library) :** Structuration des processus de gestion des services, en particulier la gestion des changements (Change Management), la gestion des incidents et l'amélioration continue.
- **COBIT (Control Objectives for Information and Related Technology) :** Alignement stratégique des choix technologiques (infrastructure 100 % open source et souveraine) sur les objectifs de performance et de maîtrise des risques de l'entreprise.
- **Guides de l'ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information) :** Référentiel de durcissement des systèmes (Linux Debian, pare-feu OPNsense, cloisonnement des réseaux par VLANs, gestion des clés SSH et authentification FreeIPA).
- **Conformité CNIL & RGPD :** Protection des données à caractère personnel traitées par l'ERP et les serveurs de fichiers, application stricte du principe de minimisation et de traçabilité des accès.

---

2. Gestion du Changement : RFC et CAB

Toute modification structurelle ou applicative sur l'infrastructure de NovaTech (mise à jour d'équipements critiques, modification de routage ou de règles de filtrage) fait l'objet d'une formalisation via une **RFC (Request For Change)** et d'une validation collégiale par le **CAB (Change Advisory Board)**.

Exemple de RFC : Mise à jour du Pare-Feu OPNsense

- **Identifiant de la RFC :** `RFC-001`
- **Demandeur :** Brandon (Pôle Réseau & Sécurité)
- **Date de soumission :** Novembre 2026
- **Type de changement :** Normal / Planifié
- **Description détaillée :** Migration et mise à jour de la pile logicielle OPNsense du pare-feu central du Site 1 vers la dernière version corrective `26.7.y`.
- **Justification métier :** Correctifs de sécurité critiques publiés par l'éditeur et prévention des vulnérabilités zero-day.
- **Impact estimé :** Coupure brève du trafic WAN (interruption estimée à 5 minutes maximum sur la passerelle principale avant bascule VRRP).
- **Évaluation du Risque :**
  - *Probabilité (1-5) :* 2
  - *Impact (1-5) :* 3
  - *Score de Risque :* $2 \times 3 = 6$ (Risque modéré maîtrisé).

- **Plan de Test :** Vérification des pings inter-VLAN, contrôle des accès web de la DMZ et tests de connectivité des postes du Site 2 via le VPN inter-sites.
- **Plan de Retour Arrière (Rollback) :** Restauration immédiate du snapshot de référence `socle-OK` pris sur l'hôte Proxmox en cas d'échec de la mise à jour.
- **Fenêtre de maintenance planifiée :** Samedi de 02h00 à 03h00 du matin (période de plus faible trafic).
- **Décision du CAB (Comité de Changement) : APROUVÉE**
- **Conditions de validation :** Réalisation impérative du snapshot préalable par Amine et tests post-installation validés par Rayan.

---

3. Plan de Capacité et Cycle de Vie à 36 Mois

Pour anticiper la croissance de NovaTech (hausse de la volumétrie et des effectifs), un plan de capacité à 3 ans est établi, s'appuyant sur les formules de projection mathématique.

3.1 Projections de Capacité

- **Croissance annuelle estimée des données :** $15\,\%$ par an ($N = 3$).
- **Formule de projection RAM :** $\mathrm{RAM_n} = \mathrm{RAM_0} \times (1{,}15)^{n}$ avec une marge de sécurité globale de $25\,\%$.
- **Seuils d'alerte et de gouvernance :**
  - *Seuil d'alerte :* $70\,\%$ d'utilisation (notification aux administrateurs).
  - *Seuil de commande :* $80\,\%$ d'utilisation (déclenchement d'une RFC d'extension matérielle).
  - *Seuil critique :* $90\,\%$ d'utilisation (gel des nouveaux déploiements).

3.2 Calendrier de Mises à Jour et Budget Prévisionnel

- **Mises à jour mineures :** Correctifs de sécurité mensuels appliqués automatiquement via scripts Ansible (géré par Brandon).
- **Mises à jour majeures (OS / Hyperviseur) :** Planifiées semestriellement lors des fenêtres de maintenance, après tests sur environnement de lab imbriqué.
- **Budget prévisionnel (0 € de licence logicielle) :**
  - Investissement concentré exclusivement sur le renouvellement et l'extension du matériel physique (disques NVMe/SSD, RAM pour l'hôte Proxmox du Site 1 et du Site 2) conformément à la stratégie de souveraineté open source.

---

4. Gouvernance des Données, Classification et Moindre Privilège

4.1 Politique de Classification des Données

Les données de l'entreprise sont réparties en quatre niveaux de sensibilité, gérés via l'annuaire centralisé **FreeIPA** et des ACL POSIX strictes sur les serveurs de fichiers :

1. **Public :** Plaquettes commerciales, site web institutionnel.
2. **Interne :** Procédures générales, notes d'information internes.
3. **Confidentiel :** Données RH, comptabilité, contrats clients/fournisseurs (accès restreint par métier).
4. **Secret :** Stratégie industrielle, secrets de fabrication, clés cryptographiques et données d'authentification (chiffrement obligatoire au repos via LUKS).

4.2 Matrice RACI (Équipe Projet & Gouvernance)

La répartition des rôles au sein de l'équipe et face aux métiers est définie ci-dessous :

Activité / Processus	Brandon (Réseau & Sécurité)	Rayan (Stockage & PRA)	Amine (Virt. & Conteneurs)	Direction / Métiers
Architecture Réseau, OPNsense & VPN Inter-Sites	**R**	C	C	A / I
Stockage, OpenZFS, iSCSI & Sauvegarde restic (PRA)	C	**R**	C	A / I
Virtualisation Proxmox, Conteneurs & Annuaire FreeIPA	C	C	**R**	A / I
Validation des RFC et Gouvernance Globale	**R**	**R**	**R**	A

(Légende : R = Réalisateur, A = Accountable / Responsable final, C = Consulté, I = Informé)

---

5. Registre des Risques Simplifié (EBIOS RM) relié aux SPOF

En cohérence avec l'analyse des risques de l'Atelier 1, voici la mise en correspondance des points uniques de défaillance (SPOF) avec le registre de risques simplifié :

Source de Risque / Menace	SPOF Cible associé	Impact Métier	Mesure de Traitement & Parade Open Source
Panne du pare-feu central	Routeur / OPNsense unique	Coupure totale des accès Internet et inter-sites	Mise en place d'une haute disponibilité active/passive (VRRP / `keepalived`).
Rupture de la liaison WAN	Lien inter-sites unique vers le Site 2	Isolement de l'agence (100 collaborateurs)	Doublement des liens opérateurs tiers avec routage dynamique OSPF (`FRRouting`).
Corruption ou panne de stockage	Baie ou disque non protégé	Perte de données ERP / Fichiers	Utilisation de pools OpenZFS en miroir, RAID et stratégie de sauvegarde 3-2-1-1-0 (`restic`).
Défaillance de l'annuaire	Serveur FreeIPA unique	Impossibilité de connexion des 250 collaborateurs	Déploiement d'une réplication multi-maître de l'annuaire FreeIPA.